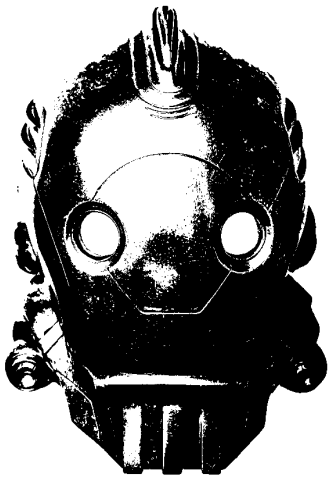
Trabajo Fin de Grado

Grado Superior en Administración de Sistemas Informáticos en Red (ASIR) IES San Vicente

SENTINEL



Infraestructura Web Segura y Monitorizada

Autor: Álex Vidal Rodenas
Tutor del TFG: Álvaro Pérez Díez

Convocatorio Junio / Curso 2024/2026

ÍNDICE

1. Módulos involucrados

Administración de Sistemas Gestores de Bases de Datos, Administración de Sistemas Operativos, Módulo Optativo (AWS), Implantación de Aplicaciones Web, Seguridad y Alta Disponibilidad, Servicios de Red e Internet.

2. Agradecimientos

[Espacio reservado para los agradecimientos personales del autor]

3. Resumen

Este proyecto, denominado SENTINEL, consiste en el diseño, despliegue y aseguramiento de una infraestructura de comercio electrónico denominada "PSICOPOMPO" al que se le hace referencia a lo largo del proyecto como “tienda_segura”. La solución integra un servidor web (Apache/PHP), una base de datos (MariaDB), un balanceador de carga (HAProxy) y un completo stack de monitorización y seguridad (Prometheus, Grafana, Loki y Wazuh) sobre una infraestructura en la nube (AWS). El objetivo principal es garantizar la alta disponibilidad, el rendimiento óptimo y la detección proactiva de incidentes de seguridad en un entorno de producción real.

4. Introducción

4.1. Contexto y justificación del proyecto

En el entorno actual, la **seguridad** y la **disponibilidad** de los servicios web son **críticas** para cualquier negocio de **comercio electrónico**. Un **fallo en el sistema** o una **brecha de seguridad** pueden suponer grandes **pérdidas económicas** y de **reputación**. Este proyecto nace de la necesidad de crear un **entorno robusto** que no solo sirva una aplicación web, sino que también se **proteja activamente** y se **monitorice en tiempo real**.

4.2. Objetivos del proyecto

- Desplegar una **arquitectura web escalable** y **segura** en **AWS**.
- Implementar un sistema de **balanceo de carga** para eliminar **puntos únicos de fallo**.
- Establecer un **stack de monitorización avanzada** (**Prometheus**, **Grafana**, **Loki**).
- Integrar un sistema de **detección y respuesta ante incidentes** (**Wazuh SIEM**).
- Aplicar medidas de **endurecimiento** (**Hardening**) en todos los **nodos**.
- Garantizar la **identidad digital** y el **cifrado de comunicaciones** (**SSL/TLS**).

4.3. Alcance y limitaciones del trabajo

- **Alcance**: Incluye desde el **diseño de la red en AWS** (**VPC**, **subredes**, **SG**) hasta la implementación del **frontend**, **backend**, **base de datos**, **balanceo**, **seguridad** y **monitorización**.

- **Limitaciones**: El proyecto se limita a recursos dentro de la **capa gratuita** o de **bajo coste** de **AWS** (**instancias t2/t3**). El desarrollo de la **aplicación web** se centra en la **funcionalidad** y **seguridad**, no en un diseño visual extremadamente complejo.

5. Análisis y contextualización de empresa/s del sector

5.1. Caracterización del sector

El **panorama actual** de la **ciberseguridad** para las **PyMEs** en España atraviesa un **momento crítico**. Tras la **digitalización acelerada** post-pandemia, el sector de los **Servicios Gestionados de IT (MSP)** ha visto cómo la **superficie de ataque** de las pequeñas empresas ha **crecido exponencialmente**.

- **Tendencias y Riesgos**: Se detecta un **aumento alarmante** en los ataques de **Ransomware as a Service (RaaS)** que tienen como objetivo el secuestro de datos transaccionales. A esto se suma el riesgo derivado de la **falta de personal cualificado** interno en las **PyMEs**, lo que genera una **brecha** entre la **innovación necesaria** y la **protección real**.

- **Oportunidades**: Existe una oportunidad estratégica en la implementación de infraestructuras IaaS **(Infrastructure as a Service)** que **permitan** a estas empresas **competir** en mercados globales con una **infraestructura elástica** y **segura**.

- **Justificación del Proyecto**: SENTINEL no es simplemente un desarrollo web, sino una solución de **Infraestructura como Servicio (IaaS) empaquetada**. Responde a la necesidad de las **PyMEs** de disponer de un e-commerce profesional, funcional y blindado mediante una arquitectura que antes solo estaba al alcance de grandes corporaciones, garantizando la continuidad de

negocio mediante la **capacidad de alta disponibilidad** y la **protección del dato.**

5.2. Productos y servicios

SENTINEL no se comercializa como un simple software, sino como un **ecosistema de infraestructura** gestionada que **prioriza** la **seguridad** y la **simplicidad**. Su valor reside en **transformar** una **arquitectura cloud compleja** en una **solución de negocio operativa**, **segura** y **escalable**.

Público Objetivo:

- **B2C (Business to Consumer)**: Clientes finales que demandan una **experiencia de compra rápida** y, sobre todo, **privacidad total** de sus **credenciales** y **datos de pago**.

- **B2B / MSP (Managed Service Providers)**: Proveedores tecnológicos que **requieren** una plataforma de **aprovisionamiento 24/7** con **disponibilidad** garantizada por contrato **(SLA)**.

- **Agencias de Desarrollo**: Partners que buscan una **base técnica robusta** sobre la cual **desplegar proyectos personalizados** para clientes finales.

Diferenciación Estratégica:

1. **Abstracción de la Complejidad ("Infraestructura Soft"): La barrera técnica se elimina** para el cliente final. Toda la arquitectura (**VPC**, **balanceadores**, **firewalls**) se gestiona de forma transparente, sistema concebido para una estrategia de **despliegue automatizado**, **permitiendo** que un **e-commerce seguro** esté **operativo** de forma ágil.

2. **Transparencia en la Observabilidad**: A diferencia de soluciones "**caja negra**", SENTINEL **ofrece** visibilidad total en tiempo real mediante un **Dashboard de Grafana**, permitiendo al administrador (o al cliente B2B) **verificar** la **salud del sistema** y los **picos de tráfico**.

3. **Hardening Profundo de Aplicación**: Blindaje específico de la capa PHP frente a vulnerabilidades críticas (**SQLi**, **XSS**, **RCE**) mediante **validación estricta** de **MIME-types** y uso de **sentencias preparadas**, superando las protecciones estándar de los hostings compartidos.

4. **Aislamiento de la Capa de Datos**: Implementación de un diseño de red con **segmentación estricta (Subred Privada)**, donde la base de datos es **inaccesible** desde el exterior, **eliminando** el vector de **ataque más común** en el e-commerce.

5. **Diseño Cloud-Agnostic**: Aunque el despliegue actual se realiza sobre servicios de **AWS**, la arquitectura se ha diseñado bajo principios de **Portabilidad**, **permitiendo** su **migración escalable** a cualquier otro proveedor cloud o entorno On-Premise sin comprometer la seguridad; aprovechando estándares como el protocolo **S3**, que podría sustituirse por **MinIO** en entornos locales para **evitar** la **dependencia** de un solo proveedor.

Impacto de SENTINEL en la Continuidad de Negocio:

- **Preparado para la Alta Disponibilidad**: El uso de balanceo de carga **(HAProxy) neutraliza** los puntos únicos de **fallo** potenciales en la capa de entrada.

- **Protección de Marca**: Se **evita** el **daño reputacional** y **legal** derivado de **brechas de seguridad** y **pérdida de datos** de clientes.

- **Toma de Decisiones Estratégicas**: La **analítica en tiempo real** permite **optimizar recursos** y **escalar** el negocio de forma inteligente **(FinOps)**.

- **Recuperación ante Desastres**: El sistema de backups automatizados en la nube **garantiza** que la empresa sea capaz de **resistir fallos críticos** sin pérdida de información transaccional.

5.3. Relación con los Objetivos de Desarrollo Sostenible (ODS)

- **ODS 9 (Industria, Innovación e Infraestructura)**: SENTINEL contribuye a crear una **infraestructura resiliente** mediante el uso de **balanceo de carga (HAProxy)** y una política de **Backups off-site en AWS S3**, garantizando que la industria digital sea capaz de **resistir fallos técnicos** o **ataques externos** sin pérdida de servicio.

- **ODS 8 (Trabajo Decente y Crecimiento Económico)**: La propuesta fomenta el **crecimiento económico seguro**. Al proteger la **integridad digital** y los **datos del cliente**, se evita la erosión económica que suponen las multas por

incumplimiento de la **RGPD** y las pérdidas por interrupción de ventas, asegurando un **entorno de trabajo digital productivo y confiable**.

5.4. Identificación de los riesgos laborales en la empresa

Más allá de los **riesgos genéricos de oficina**, un entorno de administración de sistemas e infraestructura crítica presenta riesgos específicos:

- **Gestión de Incidentes y Estrés (Burnout)**: El soporte **24/7** y la necesidad de respuesta inmediata ante ataques o caídas de servicio suponen una **carga mental elevada**. Se propone la **rotación de roles** y **protocolos** de escalado claros.

- **Fatiga por Alertas (Alert Fatigue)**: La monitorización constante de sistemas (**SIEM**/**Grafana**) puede generar desensibilización ante alertas reales por el exceso de notificaciones. Se requiere un ajuste fino de las reglas de alerta.

- **Riesgos Ergonómicos y Visuales**: **Fatiga visual** por el uso prolongado de pantallas de alta resolución y **posturas sedentarias** durante las tareas de administración.

- **Riesgos Biomecánicos**: **Trastornos musculoesqueléticos** (como el síndrome del túnel carpiano) derivados del **uso intensivo** de teclado y ratón en tareas de configuración y scripting.

5.5. Conclusiones del análisis

Tras el análisis exhaustivo del **sector MSP** y la caracterización de la **PyME tecnológica**, se concluye que el **e-commerce actual** es el **eslabón más débil** de la cadena de suministro digital debido a la **inexperiencia técnica** de los gestores y al incremento de ataques dirigidos de **Ransomware**. Las **vulnerabilidades** detectadas no son solo de código, sino de **arquitectura**: la **exposición directa** de servicios de base de datos y la **falta de visibilidad** del tráfico interno son los principales **vectores de compromiso** de datos.

La solución propuesta con **SENTINEL** no busca solo la funcionalidad de venta, sino la **resiliencia operativa**. El **aislamiento estricto** de la **base de datos** en una **subred**

privada de AWS y el uso de un **balanceador de carga** como **único punto de entrada (SSL Termination)** neutralizan los ataques de exposición directa. Esta arquitectura convierte una infraestructura tradicionalmente vulnerable en un entorno **fortificado** y alineado con los principios de **Seguridad de Confianza Cero (Zero Trust)** mediante el **aislamiento estricto** de la base de datos.

Finalmente, la integración del **stack de monitorización** (**Prometheus**/**Wazuh**) transforma la gestión reactiva en **Detección y Respuesta Proactiva**. La **observabilidad total** del sistema garantiza que cualquier **anomalía** sea detectada antes de que se convierta en una **interrupción del servicio**, cumpliendo así con los requisitos de **disponibilidad** y **confidencialidad** que exige un entorno de **producción industrial** competitivo y seguro.

6. Desarrollo del Proyecto

6.1. Metodología de trabajo

El proyecto se ha ejecutado bajo un enfoque de **Defensa en Profundidad (Defense in Depth)**, estructurando la seguridad en capas independientes para retrasar o mitigar posibles intrusiones. Para el despliegue, se ha utilizado una **metodología ágil por fases**, permitiendo validaciones continuas de cada componente:

- Enfoque Evolutivo:** Priorización de la infraestructura crítica (Red y Cómputo) antes de la integración de capas superiores (SIEM y Monitorización).

- Filosofía 'Security-First':** Cada servicio (Apache, MariaDB, PHP) ha pasado por un proceso de **hardening** inicial (desactivación de servicios innecesarios, permisos mínimos) antes de su puesta en producción.

1. Fase 1 (Infraestructura de Red):** Despliegue de la `SENTINEL-VPC` (10.0.0.0/16) con segmentación en subredes públicas y privadas para aislar la lógica de negocio.

2. Fase 2 (Seguridad Perimetral):** Implementación de **Security Groups** actuando como firewalls con estado. Se ha configurado el HAProxy con **SSL (Let's Encrypt)** para garantizar el cifrado TLS en tránsito para el dominio `psicopompo.duckdns.org`.

3. Fase 3 (Cómputo y Datos):** Provisionamiento de instancias EC2 (`t2.micro`) y despliegue "Two-Tier". Se destaca el uso de la instancia web como **Bastion Host** para acceder a la base de datos en la subred privada.

4. Fase 4 (Monitorización, Seguridad y Resiliencia):*

    - Integración de Wazuh (SIEM) y Prometheus/Grafana.

    - Implementación de Backups automatizados en AWS S3 (`tfg-sentinel-backups-alex`).

    - Auditoría de Seguridad PHP: Blindaje del cargador de imágenes (`producto_editar.php`) mediante validación de tipos MIME y lista blanca de extensiones.

6.2. Temporalización del proyecto

Se ha registrado una desviación temporal del 15% respecto a la planificación inicial. Esta desviación se atribuye principalmente a:

- La complejidad técnica de realizar una instalación offline (Side-loading) de paquetes en la subred privada.

- La configuración del SSL Termination en HAProxy, lo que requirió la gestión de certificados dinámicos.

- La resolución de problemas de borrado de productos mediante la implementación de Borrado Lógico (Soft Delete).

6.3. Actividades realizadas

- Diseño de Red:** Creación de Internet Gateway (SENTINEL-IGW) y tablas de rutas específicas.

- Fortificación de la Capa de Datos:

    - Instalación de MariaDB 10.5 en entorno aislado mediante transferencia manual de paquetes `.rpm` vía SCP.

    - Configuración de usuarios restringidos por segmento de red (`adminweb@10.0.1.%`).

- Seguridad Web (HTTPS):** Configuración de HAProxy para servir tráfico sobre el puerto 443 con certificado SSL válido.

- Auditoría de Vulnerabilidades:** Análisis de SQLi, XSS y RCE (protección del upload de archivos con `getimagesize`).

- Gestión de Backups:** Scripting en Bash para volcados de MySQL y subida automática al bucket de S3 mediante **AWS CLI**.

- Monitorización Avanzada:** Dashboard centralizado en Grafana unificando métricas de Apache, MySQL y monitorización de integridad (FIM) de Wazuh.

6.4. Recursos y tecnologías empleadas

- * **Enfoque IaaS (Infraestructura como Servicio):** Control granular sobre HAProxy, MariaDB y Agentes de Seguridad.

- * **Cloud:** AWS (EC2 t2.micro, EC2 t3.medium para SIEM, S3, VPC).

- * **Criptografía:** Let's Encrypt (SSL/TLS).

- * **SO:** Amazon Linux 2023 (Nodos Web y DB) / Ubuntu 24.04 (Nodo SIEM).

- * **Servicios:** HAProxy, Apache, MariaDB, PHP 8.2.

- * **Seguridad:** Wazuh SIEM, Fail2Ban, AWS Security Groups.
- * **Monitorización:** Prometheus, Grafana, Loki.

7. Resultados y Análisis

7.1. Análisis de los resultados y su impacto

- * **Capacidad de Respuesta (Stress Test):** Se ha validado mediante `Apache Benchmark` (`ab -n 5000 -c 50`) que el sistema alcanza un rendimiento medio de **43.64 peticiones por segundo (RPS)**.
- * **Latencia y Rendimiento:** La latencia media se ha estabilizado en **440 ms**, proporcionando una navegación fluida bajo carga moderada.
- * **Eficacia de Seguridad:** El SIEM ha demostrado una eficacia muy alta en la detección de ataques de fuerza bruta y monitorización de integridad en tiempo real.
- * **Coste del Proyecto:** El coste real acumulado en AWS es de **$2.29 USD**, lo que demuestra la viabilidad económica de la solución.

Prueba Realizada	Resultado Obtenido	Estado
Peticiones Concurrentes (50)	43.64 RPS	✅
Latencia Media	440 ms	✅
Acceso Seguro (SSL)	HTTPS Activo (Let's Encrypt)	✅
Backups Externos	S3 (Bucket: tfg-sentinel-backups-alex)	✅

7.2. Resolución de Desafíos Críticos (Troubleshooting)

Desafío Detectado	Solución Técnica Aplicada
Instalación sin Internet	Estrategia de **Side-loading** (descarga en Web y envío vía SCP a DB).
Borrado de Productos Vendidos	Implementación de **Soft Delete** (`UPDATE productos SET activo = 0`) para mantener integridad referencial.
Limitaciones AWS Academy	Documentación de la gestión de secretos como mejora futura.

8. Conclusiones y Recomendaciones

8.1. Conclusiones

El proyecto demuestra que es posible desplegar una infraestructura industrialmente viable con recursos limitados, siempre que se sigan buenas prácticas de seguridad y monitorización. Se ha logrado integrar de forma armoniosa servicios clásicos (LAMP) con stacks modernos de observabilidad y seguridad cloud.

8.2. Recomendaciones

Para futuros proyectos se sugiere el escalado horizontal dinámico (Auto-scaling groups) y la implementación de una CDN (Content Delivery Network).

8.3. Gestión de Contingencias y Continuidad de Negocio

Para mitigar los riesgos asociados a los puntos únicos de fallo (SPOF) en la arquitectura actual, se han definido los siguientes protocolos de contingencia:

Escenario de Fallo	Impacto	Protocolo de Recuperación
Caída de Nodo Web/DB	Crítico	Restauración inmediata mediante **EBS Snapshots** (Backups de volumen)
Corrupción de Datos	Alto	Recuperación de base de datos desde dumps SQL preventivos almacenados fuera del nodo.
Fallo de HAProxy	Crítico	Reconfiguración de DNS para apuntar directamente al nodo Web (modo emergencia).
Compromiso de Seguridad	Alto	Aislamiento del nodo mediante Security Groups y análisis forense con logs de Wazuh.
Saturación de Recursos	Medio	Escalado vertical preventivo (cambio de tipo de instancia EC2).

9. Bibliografía

* **AWS Documentation:** VPC, EC2, IAM and S3 Best Practices. https://docs.aws.amazon.com/

* **HAProxy Technologies:** Configuration Manual (TLS Termination). https://www.haproxy.org/

* **Wazuh SIEM:** Open Source Security Platform Documentation. https://documentation.wazuh.com/

* **Grafana Labs:** Dashboards for Prometheus and MySQL Exporter. https://grafana.com/docs/

* **OWASP Top 10:** Guide for PHP Security (SQLi, XSS, RCE protection). https://owasp.org/www-project-top-ten/

10. Anexos

1. **Diagrama de Red SENTINEL:** Estructura de la VPC y subredes. ([docs/diagrama_red.md])

2. **Panel de Estadísticas de HAProxy:** Salud de los nodos y estado del certificado SSL. ([capturasfase4/Panel de Estadísticas de HAProxy.png])

3. **Resultados de Apache Benchmark:** Captura de métricas de rendimiento final. ([capturasfase4/Terminal con los resultados de ab.png])

4. **Monitorización Unificada (Grafana):** Picos de carga y métricas de Apache/MySQL. ([capturasfase4/Pico en Grafana.png])

5. **Auditoría de Costes:** Dashboard de facturación de AWS. ([capturasfase4/costes1.png])

6. **Ficha de autoevaluación:** Calificación del desempeño técnico y gestión del autor. (Ver apartado 10.6)

7. **Ficha de coevaluación:** Nota aclaratoria sobre desarrollo individual. (Ver apartado 10.7)

10.6. Ficha de autoevaluación

A continuación, se presenta la valoración del autor sobre el desempeño y proceso de ejecución del proyecto individual SENTINEL:

| Ítem de Evaluación | Calificación (1-10) | Observaciones Técnicas |

| :--- | :---: | :--- |

| **Cumplimiento de objetivos técnicos** | 9.0 | Implementación completa del stack de seguridad y monitorización en AWS. |

| **Gestión del tiempo y planificación** | 7.5 | Desviación del 15% por la complejidad de la instalación offline (Side-loading) en subred privada. |

| **Capacidad de resolución (Troubleshooting)** | 9.5 | Resolución exitosa de desafíos en conectividad SSH, SSL y borrado lógico de productos. |

| **Calidad de la documentación técnica** | 9.0 | Documentación detallada de la arquitectura, planes de contingencia y auditoría económica. |

| **Integración de herramientas (SIEM/Grafana)** | 8.5 | Visualización efectiva de métricas, aunque con margen de mejora en el ajuste fino de reglas de Wazuh. |

10.7. Ficha de coevaluación

Nota Aclaratoria: Dado que el proyecto SENTINEL ha sido desarrollado de forma **individual** por un único integrante, no procede el proceso de coevaluación entre pares.

No obstante, se ha realizado una evaluación continua basada en el feedback del tutor y el cumplimiento de los estándares de calidad del entorno Cloud.

| Miembro del Equipo | Rol | Aportación | Evaluación |

| :--- | :--- | :--- | :--- |

| **Alex Vidal Ródenas** | Autor Único | Diseño, despliegue y documentación integral. | N/A |

| **Equipo de Trabajo** | N/A | Proyecto Individual | **N/A** |

---

11. Trabajo Futuro y Líneas de Mejora

Dada la naturaleza evolutiva del proyecto SENTINEL y las limitaciones de presupuesto impuestas por el entorno de aprendizaje, se han identificado las siguientes áreas de mejora para una futura transición a un entorno de producción industrial:

11.1. Alta Disponibilidad (HA) Real

Para eliminar los puntos únicos de fallo (SPOF) detectados, se planea:

* **Cluster de Balanceo:** Implementar un segundo nodo HAProxy sincronizado mediante **Keepalived** y una IP flotante (VIP).

* **Replicación de Datos:** Sustituir la instancia única de MariaDB por un entorno de replicación **Master-Slave** o migrar a **Amazon Aurora** con Multi-AZ habilitado.

11.2. Automatización e Infraestructura como Código (IaC)

La configuración actual manual de AWS se optimizará mediante:

* **Terraform:** Para definir la red, instancias y grupos de seguridad de forma declarativa.

* **Ansible:** Para automatizar el aprovisionamiento de software y la gestión de configuraciones, eliminando la intervención manual en los servidores.

11.3. Seguridad Proactiva y Gestión de Parches

* **IDPS de Red:** Integrar un sistema de detección y prevención de intrusiones a nivel de red como **Snort** o **Suricata** en la entrada de la VPC.

* **Bastion & Proxy:** Implementar un **Proxy de aplicación** (Squid) para permitir actualizaciones seguras en la subred privada de forma controlada, eliminando definitivamente la dependencia del side-loading manual, además, esto también sirve para **centralizar las actualizaciones de seguridad.**

* **Gestión de Identidades y Secretos:** Integrar **AWS Secrets Manager** para la rotación automática de las credenciales de MariaDB, eliminando el uso de contraseñas embebidas en los archivos `.php` del servidor.

11.4. Escalabilidad y Elasticidad (FinOps)

* **Auto Scaling:** Configurar grupos de auto-escalado basados en métricas de CPU/RAM de Prometheus para añadir dinámicamente nodos web durante picos de carga.

* **Content Delivery Network (CDN):** Implementar **CloudFront** para el almacenamiento en caché de contenido estático (imágenes de la tienda), reduciendo la carga en el servidor de origen.